



By Nitesh Singh

Job Ready Free Live Training To Become A

SOC

Analyst L1 For Free

Defronix Cyber Security → <https://defronix.com>



Cyber Kill Chain Methodology

- *Cyber Kill Chain – attacker lifecycle*
- *Hacking Methodologies – practical execution flow*

The Cyber Kill Chain is a framework created by Lockheed Martin to explain how cyber attacks happen step-by-step.

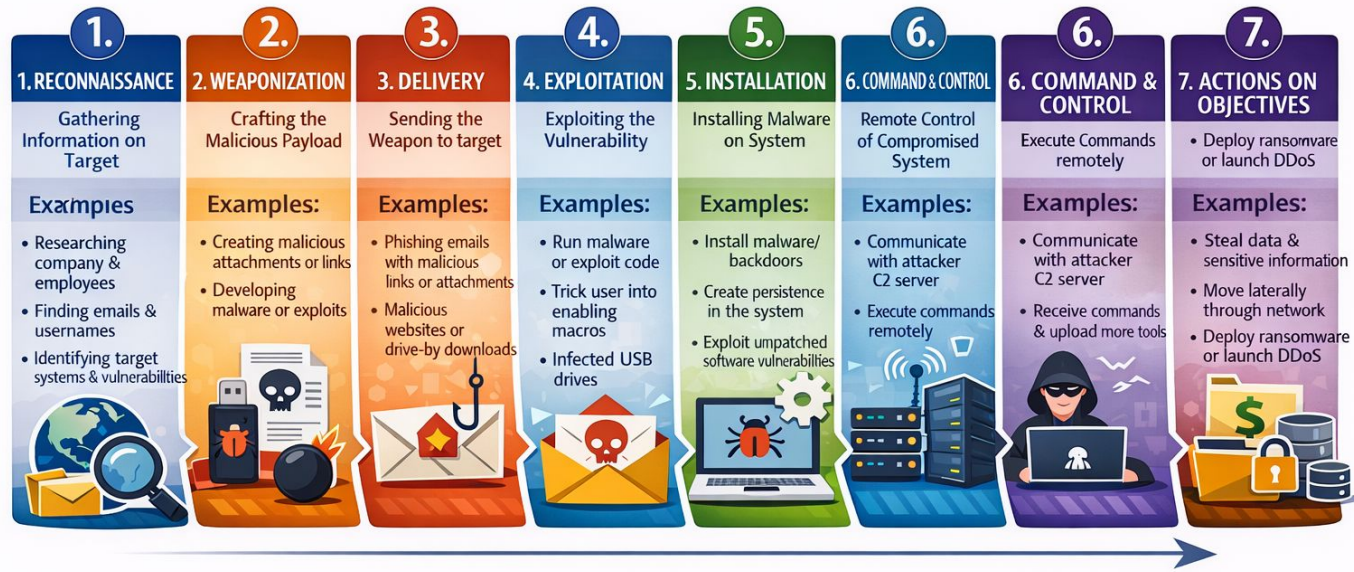
It is a linear model that focuses on the attacker's journey from the outside in. By breaking the chain at any point, you stop the entire attack.

7 Stages Of Cyber Kill Chain



The Cyber Kill Chain

Stages of a Cyber Attack



7 Stages Of Cyber Kill Chain



Phase	Description	Key Ethical Hacking Activity
Reconnaissance	Gathering intel on the target (OSINT).	Passive & Active footprinting.
Weaponization	Coupling an exploit with a backdoor (e.g., a PDF with a script).	Payload crafting with Metasploit/Cobalt Strike.
Delivery	Sending the weapon to the victim (Email, USB, Web).	Phishing simulations.
Exploitation	The "Boom" moment—triggering the vulnerability.	Executing a buffer overflow or SQL injection.
Installation	Installing persistent malware on the victim's asset.	Setting up persistent shells or rootkits.
C2 (Command)	Establishing a remote channel for control.	Configuring C2 frameworks like Mythic or Havoc.
Actions	Final goal: Data theft, encryption, or destruction.	Data exfiltration testing (DLP bypass).

Reconnaissance (Information Gathering)



What happens here?

Attacker **collects information** about the target *without touching it directly* (mostly).

Attacker's mindset:

“Before attacking, I must know **who**, **what**, **where**, and **how**.”

Real-world examples:

- Finding employee emails
- Identifying company domains & subdomains
- Finding technologies used (WordPress, Apache, IIS)
- Studying LinkedIn profiles
- Finding leaked passwords

Tools & Techniques:

- Google dorking
- WHOIS lookup
- DNS enumeration
- OSINT (Open Source Intelligence)

Defensive view (SOC):

- Monitor excessive DNS queries
- Track scanning behavior
- Watch unusual OSINT-based phishing patterns



What happens here?

Attacker prepares a **payload + exploit**.

Payload = what runs after exploit

Exploit = how vulnerability is abused

Example:

- Malware embedded in a PDF
- Reverse shell hidden in Word macro
- Exploit for an unpatched service

Attacker's mindset:

"I have info. Now I build the weapon."

SOC perspective:

- File hash analysis
- Malware sandboxing
- Detect known exploit signatures



What happens here?

Weapon is **delivered** to the victim.

Common delivery methods:

- Phishing email
- Malicious attachment
- Drive-by website
- USB drop
- Compromised ads

Example:

HR receives a “Resume.pdf.exe”
via email.

SOC controls:

- Email gateway filtering
- URL reputation
- Attachment sandboxing



What happens here?

The vulnerability is **actually triggered**.

Examples:

- User clicks malicious link
- Software buffer overflow
- Outdated plugin exploited
- Macro execution

- **Important concept:**

No exploitation = no compromise

- SOC teams try to **break the chain here**.



What happens here?

Malware installs **persistence**.

Persistence means:

“Even if system restarts, I stay.”

Techniques:

- Registry run keys
- Scheduled tasks
- Startup folders
- Backdoor users

SOC focus:

- Endpoint Detection & Response (EDR)
- Registry monitoring
- Autorun analysis



Lifecycle of a Command and Control Attack

cymulate





What happens here?

Compromised system **talks to attacker's server**.

Examples:

- Beacons every 60 seconds
- DNS tunneling
- HTTPS-based C2

SOC detection:

- Abnormal outbound traffic
- Beacons patterns
- Known bad IPs/domains



What happens here?

Attacker does what they came for.

Objectives include:

- Data theft
- Ransomware deployment
- Credential dumping
- Lateral movement
- Financial fraud

This is where maximum damage happens.



Reconnaissance: Collecting information (IPs, DNS, employee names).

Scanning: Using tools like **Nmap** or **Nessus** to find open ports and live services.

Gaining Access: This is the actual "hack"—breaking through the perimeter or using credentials.

Maintaining Access: Ensuring you don't lose your connection if the user reboots or the network resets (Persistence).

Clearing Tracks: Deleting logs and removing tools to avoid detection by the Blue Team (Defenders).



Cyber Kill Chain	Hacking Methodology
Reconnaissance	Reconnaissance
Weaponization	Exploit prep
Delivery	Payload delivery
Exploitation	Gaining access
Installation	Maintaining access
C2	Persistent control
Actions	Post-exploitation



What is Alert Reporting?

Alert reporting is the process of **formally documenting**:

- What was detected
- What was analyzed
- What conclusion was reached
- What action was taken or recommended

If it's **not documented**, it **didn't happen** (SOC golden rule).



Why Alert Reporting Matters

- Creates audit trail
- Enables handover between shifts
- Supports incident response
- Protects analysts legally
- Helps improve detections

In real SOC's, **bad reporting = bad analyst**, even if triage was correct.



Example: Tier-1 Alert Report (Short)

Summary:

PowerShell executed with encoded command triggered by Word document on finance user system.

Analysis:

Execution occurred outside business hours. Parent process was winword.exe. External connection observed.

Verdict:

True Positive – suspicious execution.

Recommendation:

Escalate to SOC L2 for containment.

That's it. **Clear, factual, defensible.**



What is Escalation?

Escalation means:

“This alert is beyond Tier-1 authority and requires higher expertise or action.”

Tier-1 **does not fix incidents.**

Tier-1 **identifies and hands over correctly.**



When Should Tier-1 Escalate?

Escalate when ANY of the following are true:

Condition	Example
Confirmed malicious activity	Malware execution
Privileged account involved	Admin user
Critical asset affected	Server / DC
Multiple alerts correlated	Phishing + execution
Data risk exists	Possible exfiltration
Policy requires escalation	Severity High/Critical

Escalation is **not failure**, it's professionalism.



Example: Tier-1 Escalation Note

Escalation Reason:

Confirmed suspicious PowerShell execution with external communication.

Evidence Attached:

Process tree, command line, destination domain.

Severity:

High

Recommended Action:

Endpoint isolation and memory analysis.

This makes L2 trust you instantly.



What is SOC Communication?

SOC communication is:

- Analyst → Analyst
- Analyst → IR team
- Analyst → IT/Admin
- SOC → Management

You are translating **technical risk into actionable information**.



Communication Principles (SOC Standard)

- Clear
- Factual
- No assumptions
- No panic language
- No blame

✗ “System hacked badly!!!”



“Suspicious activity detected, under investigation.”



Communication Types in SOC

Internal SOC Communication

Used during:

- Shift handover
- Escalation
- Collaboration

Example (Handover Note):

Alert escalated to L2. Endpoint pending isolation. Monitoring ongoing.



IT / Admin Communication

Used when action is needed.

Example:

Please isolate FIN-LAP-07 from the network as suspicious activity was detected.

Not:

“There is malware everywhere”



Management Communication (High-Level)

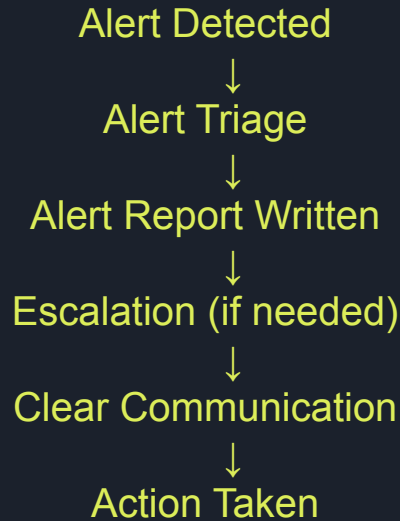
Management doesn't want logs.
They want **impact + status**.

Example:

Suspicious activity detected on one finance user system. No evidence of data exfiltration so far. Incident under investigation.



How Reporting, Escalation & Communication Fit Together



Miss any step → SOC failure.